

A Secure Natural Language Query Interface for Enterprise Databases with Access Control and On-Premise LLMs

firstname lastname, firstname lastname, firstname lastname, firstname lastname

Department of Computer Engineering,

Sardar Patel Institute of Technology, Mumbai, India

{firstname.lastname23, firstname.lastname23, firstname.lastname23, firstname.lastname23, anant_nimkar}@spit.ac.in

Abstract—TO DO: Write this post impln.

Index Terms—Text-to-SQL, RAG, Access Control, LLM Security, Prompt Injection

I. INTRODUCTION

TO DO

II. RELATED WORK

Natural language query interfaces for enterprise databases span several research threads - Text-to-SQL generation, LLM reliability, access control, and adversarial security - each of which has advanced while remaining largely isolated from the others. The gap this work addresses lies at their intersection.

A. Text-to-SQL Systems

Spider [1] established cross-schema generalization as the fundamental evaluation criterion, exposing that earlier high-accuracy results were artifacts of schema memorization. BIRD [2] extended this to enterprise-realistic conditions - noisy values, external knowledge dependencies - revealing that state-of-the-art LLMs achieve roughly half the accuracy of human annotators. Failures trace primarily to schema linking and content misunderstanding rather than reasoning limitations, defining where generation pipelines must be reinforced.

DIN-SQL [3] decomposed generation into sequential stages - schema linking, classification, adaptive generation, and self-correction - with schema linking driving the largest individual gains. SEA-SQL [4] extended this by injecting actual column values during schema grounding and replacing static self-correction with an iterative execute-reflect-correct loop that catches runtime failures invisible to LLM-internal reasoning. Its model-agnostic design confirms that local open-source models are architecturally competitive when the pipeline is properly grounded. PICARD [5] addresses a different layer, enforcing schema-aware syntactic validity through constrained decoding without modifying the underlying model.

None of these systems consider the authorization dimension. All present the full database schema irrespective of the querying user's access scope - a structural limitation rather than an implementation gap. The pipelines have no concept of a per-user schema view, so restricted users receive schema information they are not permitted to see before any query executes.

B. Hallucination and Reliability

Correctness metrics do not characterize failure modes, and different failure classes require different defenses. A systematic study of LLM-generated code [6] finds that the dominant failure class - wrong predicates, mismatched aggregation, incorrect return semantics - produces queries that execute without error yet return wrong results. Model-intrinsic limitations drive the vast majority of these cases, placing a ceiling on what prompt engineering alone can achieve. Pavel et al. [7] identify a complementary failure: once hallucination of non-existent identifiers is eliminated through richer schema grounding, a residual disambiguation error persists in which the model selects a plausible but incorrect identifier from similar alternatives - surviving syntax validation entirely. Both studies converge on the same conclusion: a validity layer is necessary but not sufficient, and execution-grounded feedback is structurally required rather than optional.

C. Access Control and Data Governance

Two complementary works define the authorization design space yet together expose a shared blind spot. Jeong and Lee [8] show that centralized policy merging silently drops attributes and causes unintended access, and instead delegate validation to each provider's native IAM system at retrieval time, achieving zero unauthorized disclosures across heterogeneous RBAC and ABAC policies. Gadi [9] demonstrates that prompt-level access instructions are reliably overridden by user natural-language assertions; PostgreSQL Row-Level Security enforced at the storage layer guarantees the worst-case outcome is an empty result set rather than unauthorized data.

Despite covering opposite enforcement boundaries, both share the same blind spot. The database schema is serialized into the LLM's prompt before retrieval filtering or execution enforcement applies, giving restricted users visibility into schema elements they cannot query. When column values are additionally injected for semantic grounding, an access-control-unaware retrieval step exposes values from rows the user is not permitted to see. Neither framework addresses this prompt-construction leakage.

D. Prompt Injection and Adversarial Threats

Prompt injection is rated the highest-severity risk in deployed LLM systems [10]: system instructions and user input share the same token context, making instruction override possible without any knowledge of model internals. Zhao et al. [11] exploit this by inserting a replica of the assistant-role prefix into the user-controlled segment, achieving over 85% attack success on frontier models; established defenses provide limited mitigation against this structural manipulation.

The threat extends to training time. Lin et al. [12] show that Text-to-SQL models can be backdoored through minimal dataset poisoning, generating destructive SQL under semantically natural triggers while behaving normally on clean inputs - bypassing all tested pipeline-level defenses, which operate on query structure rather than model behavior. Layered multi-agent defenses [13] and structured prompt engineering patterns [14] achieve near-complete mitigation against inference-time attacks, but both assume a trustworthy underlying model, leaving training-time compromise unaddressed.

E. Enterprise Deployment Constraints

The case for local, model-agnostic deployment has a concrete empirical basis. Carlini et al. [15] show that training data memorization scales with model size and data duplication, meaning fine-tuning on proprietary schema data creates measurable extraction risk. This motivates runtime schema injection over weight encoding - a principle formalized by Lewis et al. [16] through RAG, which enables knowledge updates via index replacement rather than retraining. Madupati et al. [17] operationalize this within a Zero Trust pipeline, demonstrating that access-controlled metadata-driven prompt construction maintains accuracy without cloud dependency. The CSA ZTA framework [18] further notes that agentic tool-calling amplifies the blast radius of a successful injection across connected systems - a consideration directly relevant to multi-backend deployments.

F. Natural Language Interfaces for NoSQL

Extending natural language query interfaces to document-oriented backends introduces structurally distinct challenges. Lu et al. [19] establish that SQL-to-NoSQL cascading fails even when a strong model is given ground-truth SQL and full schema context, validating native query generation as an independent task; execution-grounded correction proves necessary here as well, confirming its generality across backends. Qin et al. [20] show that schema linking and operator mapping must be treated as separate subtasks for reliable generation, as architectures optimized for one do not transfer cleanly to the other. At the practitioner level, MongoDB's NLP query documentation [21] identifies annotated schema grounding with representative sample documents as the single most impactful prompt component - consistent with the schema injection evidence across the Text-to-SQL literature.

G. Research Gap

The bodies of work above collectively cover the field but leave their intersection unaddressed. Text-to-SQL pipelines have reached strong benchmark accuracy, yet all expose the full database schema at prompt construction time - a constraint none treat as a design variable. Access control frameworks enforce authorization at retrieval or execution boundaries, but schema elements and injected column values reach the model before either boundary applies. Adversarial defenses handle inference-time attacks effectively but uniformly assume clean model weights, leaving training-time backdoors unaddressed within any single generation system.

The deployment constraint compounds this further. All high-accuracy systems depend on proprietary API access, coupling generation quality to cloud data exposure. No prior work jointly evaluates a locally-hosted, model-agnostic pipeline against both correctness benchmarks and adversarial robustness within a unified security architecture. Demonstrating that schema-level filtering, value-level filtering, and prompt-level defense can be integrated without degrading query accuracy - across both relational and document-oriented backends - is the open problem this work targets.

REFERENCES

- [1] T. Yu, R. Zhang, K. Yang, M. Yasunaga, D. Wang, Z. Li, J. Ma, I. Li, Q. Yao, S. Roman, Z. Zhang, and D. Radev, "Spider: A large-scale human-labeled dataset for complex and cross-domain semantic parsing and text-to-sql task," in *Proceedings of the 2018 Conference on Empirical Methods in Natural Language Processing*. Brussels, Belgium: Association for Computational Linguistics, 2018, pp. 3911–3921. [Online]. Available: <https://aclanthology.org/D18-1425/>
- [2] J. Li, B. Hui, G. Qu, J. Yang, B. Li, B. Li, B. Wang, B. Qin, R. Geng, N. Huo, F. Huang, Y. Li, W. Sun, L. Jiang, Y. Cao, R. Cheng, J. Lin, K. Chang, Y. Li, and G. Sun, "Can LLM already serve as a database interface? A BIG bench for large-scale database grounded text-to-SQLs," in *Advances in Neural Information Processing Systems*, vol. 36, 2023. [Online]. Available: <https://bird-bench.github.io/>
- [3] M. Pourreza and D. Rafiei, "DIN-SQL: Decomposed in-context learning of text-to-SQL with self-correction," in *Advances in Neural Information Processing Systems*, vol. 36, 2023, pp. 36339–36348. [Online]. Available: https://proceedings.neurips.cc/paper_files/paper/2023/hash/83fc8fab1710363050bbd1d4b8cc0021-Abstract-Datasets_and_Benchmarks.html
- [4] C. Li, Y. Shao, Y. Li, and Z. Liu, "SEA-SQL: Semantic-enhanced text-to-SQL with adaptive refinement," *Frontiers of Computer Science*, vol. 20, no. 3, p. 2003602, 2026. [Online]. Available: <https://journal.hep.com.cn/fcs/EN/10.1007/s11704-025-41136-3>
- [5] T. Scholak, N. Schucher, and D. Bahdanau, "PICARD: Parsing incrementally for constrained auto-regressive decoding from language models," in *Proceedings of the 2021 Conference on Empirical Methods in Natural Language Processing*. Online and Punta Cana, Dominican Republic: Association for Computational Linguistics, 2021, pp. 9895–9901. [Online]. Available: <https://aclanthology.org/2021.emnlp-main.779/>
- [6] T. Liu et al., "Beyond functional correctness: Exploring hallucinations in LLM-generated code," 2026, paper details incomplete - unable to verify full citation.
- [7] T. Pavel et al., "Hallucination in LLM-based code generation: An automotive case study," 2025, paper details incomplete - unable to verify full citation.
- [8] J. Jeong and S.-G. Lee, "Permission-aware RAG: Identity and access management (IAM)-based access filtering in multi-resource environments," *IEEE Access*, vol. 13, pp. 192819–192835, 2025. [Online]. Available: <https://snu.elsevierpure.com/en/publications/permission-aware-rag-identity-and-access-management-iam-based-acc/>

- [9] G. Evron, "Addressing access control challenges in text-to-SQL LLM chatbots: A row-level security approach," LinkedIn Article, 2024. [Online]. Available: <https://www.linkedin.com/pulse/addressing-access-control-challenges-text-to-sql-llm-chatbots-gadi-xpf6c>
- [10] OWASP Foundation, "OWASP top 10 for LLM applications 2025," OWASP Gen AI Security Project, 2025. [Online]. Available: <https://genai.owasp.org/>
- [11] J. Zhao, K. Chen, W. Zhang, and N. Yu, "SQL injection jailbreak: A structural disaster of large language models," in *Findings of the Association for Computational Linguistics: ACL 2025*. Vienna, Austria: Association for Computational Linguistics, 2025, pp. 6871–6891. [Online]. Available: <https://aclanthology.org/2025.findings-acl.358/>
- [12] M. Lin *et al.*, "ToxicSQL: Migrating SQL injection threats into text-to-SQL systems via backdoor attacks," 2025, arXiv:2503.05445. [Online]. Available: <https://arxiv.org/abs/2503.05445>
- [13] S. M. Hossain *et al.*, "A multi-agent LLM defense pipeline against prompt injection attacks," 2025, arXiv:2509.14285. [Online]. Available: <https://arxiv.org/abs/2509.14285>
- [14] T. Sudarsan *et al.*, "Secure prompt engineering patterns for LLM applications," in *IEEE International Conference on Artificial Intelligence and Cloud Computing (ICAIC)*, 2026, conference paper - full details unavailable.
- [15] N. Carlini, D. Ippolito, M. Jagielski, K. Lee, F. Tramèr, and C. Zhang, "Quantifying memorization across neural language models," in *International Conference on Learning Representations*, 2023. [Online]. Available: https://openreview.net/forum?id=TatRHT_1cK
- [16] P. Lewis, E. Perez, A. Piktus, F. Petroni, V. Karpukhin, N. Goyal, H. Küttler, M. Lewis, W.-t. Yih, T. Rocktäschel, S. Riedel, and D. Kiela, "Retrieval-augmented generation for knowledge-intensive NLP tasks," in *Advances in Neural Information Processing Systems*, vol. 33, 2020, pp. 9459–9474. [Online]. Available: <https://proceedings.neurips.cc/paper/2020/hash/6b493230205f780e1bc26945df7481e5-Abstract.html>
- [17] T. Madupati *et al.*, "Secure LLM-oriented data engineering pipelines in multi-cloud environments," in *International Conference on Computing, Communication, and Intelligent Systems (ICCCIS) / ICCTDC*, 2025, conference paper - full details unavailable.
- [18] Cloud Security Alliance, "Using zero trust to secure enterprise information in LLM environments," Cloud Security Alliance, Tech. Rep., March 2026. [Online]. Available: <https://cloudsecurityalliance.org/artifacts/using-zero-trust-to-secure-enterprise-information-in-llm-environments>
- [19] J. Lu, Y. Song, Z. Qin, H. Zhang, C. Zhang, and R. C.-W. Wong, "Bridging the gap: Enabling natural language queries for NoSQL databases," 2025, arXiv:2502.11201. [Online]. Available: <https://arxiv.org/abs/2502.11201>
- [20] Z. Qin, Y. Song, J. Lu, Y. Song, S. Li, and C. J. Zhang, "MultiTEND: A multilingual benchmark for natural language to NoSQL query translation," in *Findings of the Association for Computational Linguistics: ACL 2025*. Vienna, Austria: Association for Computational Linguistics, 2025, pp. 24 632–24 657. [Online]. Available: <https://aclanthology.org/2025.findings-acl.1265/>
- [21] MongoDB Inc., "Natural language to MongoDB query with atlas and compass," 2025, accessed: 2026-04-05.